PROJECT 03 • IAM & GRC PORTFOLIO

Access Review & IAM Control Test Report

Asterbridge Care Technologies | Version 1.0 | Testing date: 14 October 2026

Controlled lab assessment. This document does not represent a production audit or management access certification.

Executive summary

A read-only inventory of nine accounts in the Asterbridge organizational unit was compared with a predefined, simulated role-access matrix. The original technical comparison found no deviations. A deliberate unauthorized assignment of the Hamilton Front Desk group to Hannah Reid, a Kitchener receptionist, was then detected and shown to allow Hamilton folder access. The group was removed and access was retested from a fresh Windows session.

Stage	Result	Interpretation
Clean baseline	9 matches, 0 exceptions	Expected and actual GRP-* memberships aligned
Controlled exception	8 matches, 1 exception	Hamilton access assigned beyond the role baseline
After remediation	9 matches, 0 exceptions	Membership removed and effective access restriction restored

Technical verdict: The tested role comparison identified the injected exception and subsequent retesting confirmed removal of the unauthorized clinic permission. All nine recorded reviewer decisions remain Pending, so formal certification has not taken place.

Scope at a glance

In scope	Not established by this exercise
9 Asterbridge OU user accounts (8 enabled, 1 disabled)	Whole-domain workforce or external platforms
Groups prefixed GRP-* and two lab NTFS clinic folders	All nested roles, administrative access and applications
Separate privileged-group inventory (read only)	Privileged access authorization or ongoing monitoring
Controlled, fictional account access exception	Real incident response or independent audit opinion

1. Objectives and criteria

Control objective: Asterbridge users should receive access consistent with their assigned roles, excessive group memberships should be identifiable, and revoked access should no longer permit restricted resource access after the user establishes a new session.

The role-access comparison used a simulated authorization baseline defined for the lab. It was not approved by a real department owner. Each identity retained ReviewerDecision = Pending in the original exports.

2. Evidence and procedures

ID	Evidence source	Purpose
SRC-01	AD-Access-Inventory.csv	In-scope user and group inventory
SRC-02	Access-Certification-Baseline.csv	Pre-test approved-role comparison
SRC-03	Access-Certification-Exception.csv	Detection of deliberate excess membership
SRC-04	Access-Certification-PostRemediation.csv	Post-change comparison
SRC-05	Privileged-Access-Inventory.csv (internal only)	Recursive privileged-group inventory

Method: (1) export Asterbridge identities and GRP-* memberships; (2) compare memberships with the simulated role matrix; (3) inject one deliberate cross-clinic role assignment; (4) run the comparison again; (5) sign in to the Windows workstation to verify effective access; (6) remove the membership; (7) sign in again; and (8) rerun the technical review.

3. Population and snapshot results

The user population in all three certification snapshots contains the same nine usernames. The original inventory shows eight enabled employees and one disabled employee (Olivia Bennett). The exception export flags exactly one user, Hannah Reid, with GRP-CLINIC-HAM-FrontDesk recorded in ExcessAccess. The post-remediation export reports nine Match statuses and no ExcessAccess values.

4. Control test finding: IAM-F03

Attribute	Documented result
Title	Controlled cross-clinic excessive access
Affected identity	Hannah Reid (hreid), Kitchener Front Desk
Expected groups	GRP-CORP-AllStaff; GRP-CLINIC-KIT-FrontDesk
Exception	GRP-CLINIC-HAM-FrontDesk added intentionally
Detection	Exception status and ExcessAccess populated in CSV
Effect	Hamilton test-file creation and read succeeded after fresh sign-in
Remediation	Unauthorized Hamilton membership removed
Retest	Hamilton existing file read denied; Kitchener file read allowed
Post-check	9 / 9 role-group comparisons match; no remaining recorded exception
Classification	Controlled lab finding; technically closed

The injected group membership was the known cause of the observed access difference in the test. The exercise does not establish how such a change would arise in normal operations, and it is not evidence of a real unauthorized user or breach.

Risk and control interpretation

A misplaced role membership can bypass organizational separation enforced through group-based NTFS permissions. In this lab, the unintended Hamilton assignment allowed access to a restricted folder. The scenario illustrates the value of periodic access review, owner attestation, prompt remediation, and verification of effective permissions after the user refreshes their session.

A qualitative medium risk rating could be reasonable for this synthetic scenario, but no formal likelihood-impact scoring, clinical data sensitivity assessment, or validated production risk appetite was performed. Accordingly, this report does not assign a formal residual-risk score.

Timeline of evidence

Sequence	Activity	Outcome
1	Clean comparison	Nine Match records
2	Extra Hamilton membership added	Hannah account has both clinic groups
3	Recomparison and workstation test	Exception detected; unauthorized read/write allowed
4	Membership removal and fresh sign-in	Hamilton access denied; Kitchener retained
5	Final comparison	Nine Match records

5. Selected test evidence

These unmodified screenshots were captured during the lab on 14 October 2026. Full-resolution evidence files are provided separately in the Project 3 evidence directory.

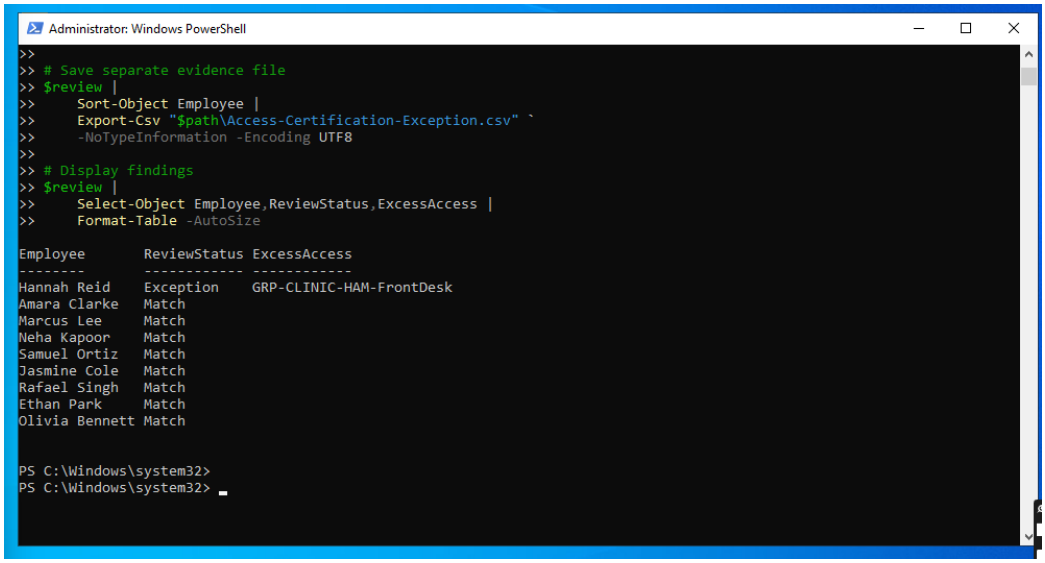


Figure 1. Automated certification flagged Hannah with excess Hamilton access.

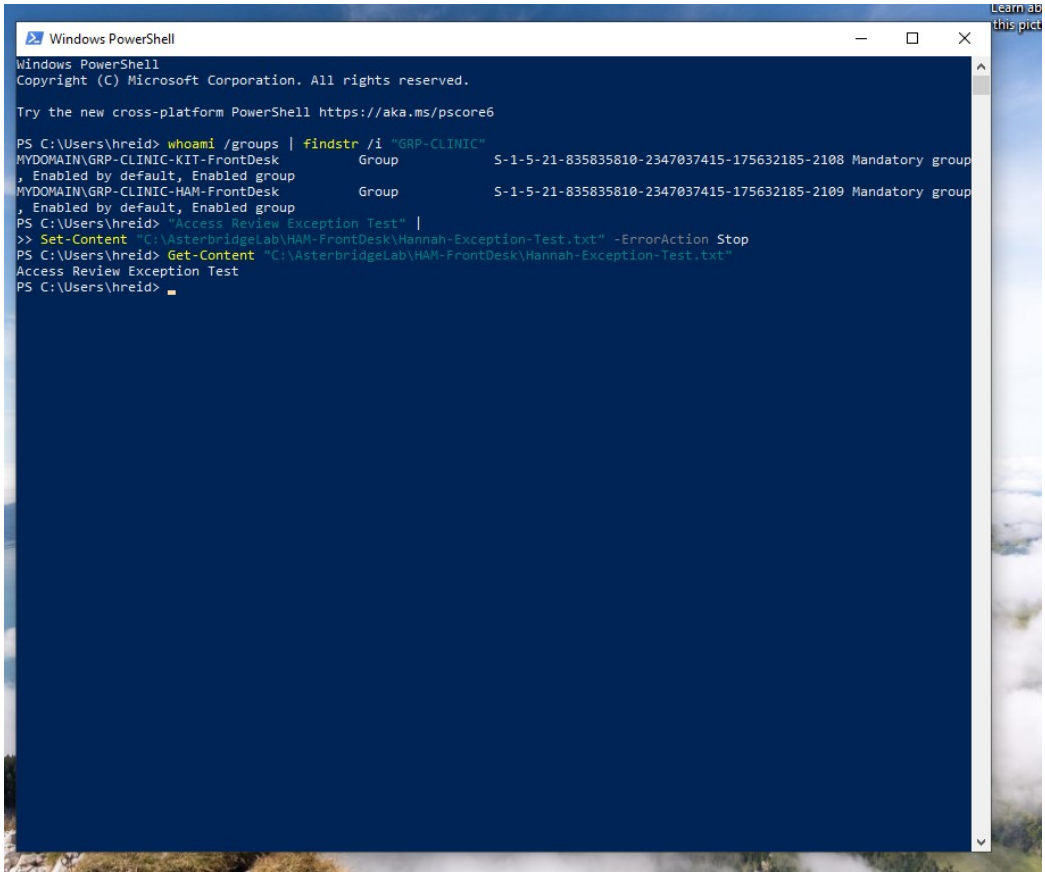


Figure 2. Hannah was able to create and read the Hamilton test file while the extra membership was active.

6. Remediation verification evidence

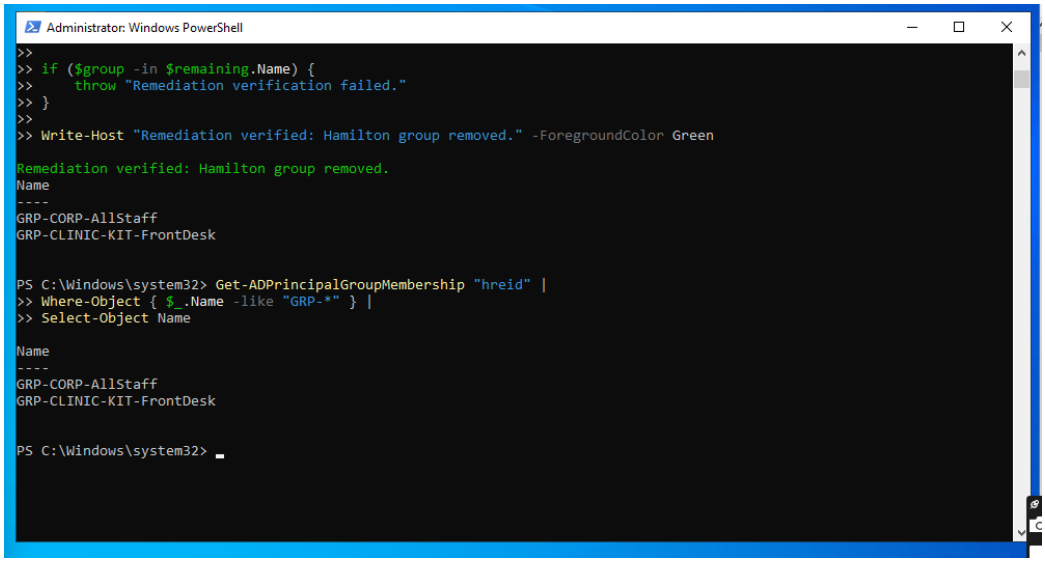


Figure 3. Directory lookup showed only the corporate and Kitchener role groups after remediation.

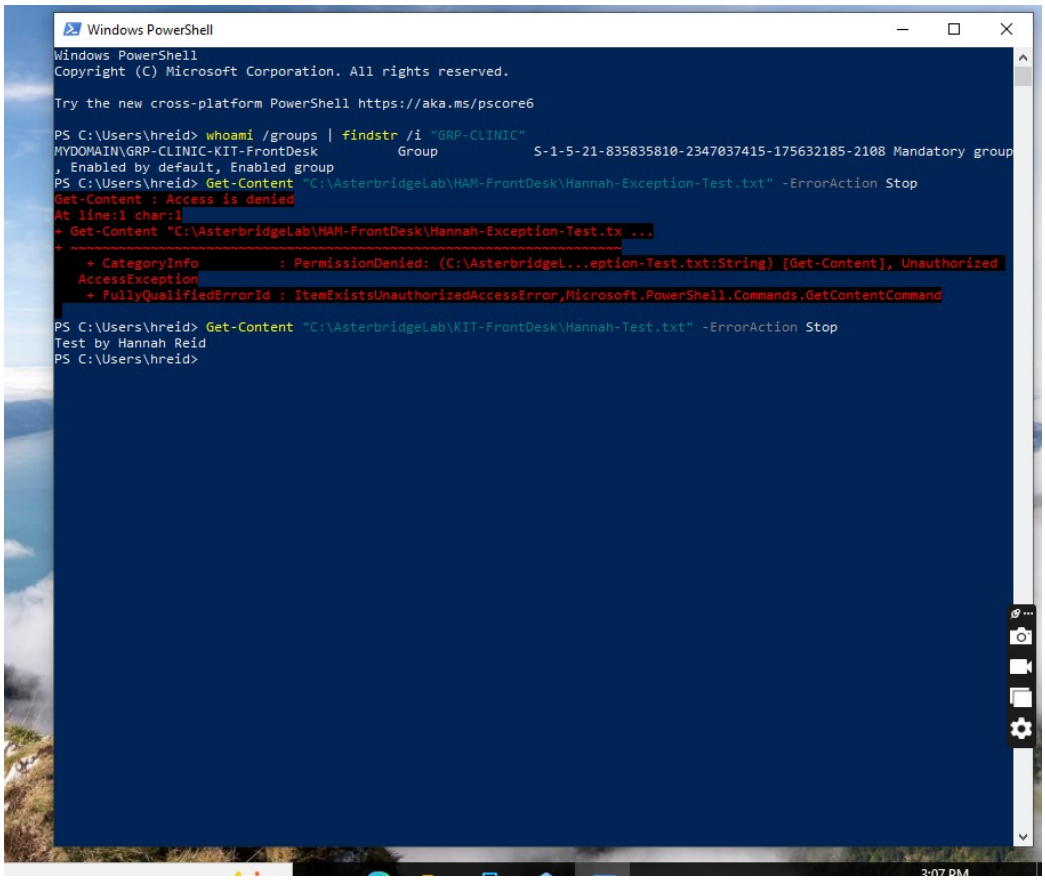


Figure 4. Following a fresh sign-in, the Hamilton file read was denied and Kitchener remained accessible.

7. Privileged access and separate observations

A separate recursive review of selected privileged AD groups identified membership for the built-in Administrator and a dedicated lab administrator. A subsequent direct-membership display differentiated directly assigned groups from nested memberships. No ordinary Asterbridge employee account appeared in the privileged-group results reviewed. This inventory alone is insufficient to conclude that all privileged access is appropriately authorized or controlled.

The default domain password policy was separately observed to allow a seven-character minimum and to set the account lockout threshold to zero. Fine-grained policies and compensating controls were not fully evaluated. These items are logged as out-of-scope observations, not concluded access-certification findings.

8. Control alignment (illustrative)

Reference	Relevance in this lab
NIST CSF 2.0 PR.AA-05	Access entitlements are managed, reviewed and aligned with least privilege
ISO/IEC 27001:2022 Annex A 5.18	Access rights provisioning, review, adjustment and removal
SOC 2 CC6.3 (illustrative)	Authorization and modification/removal of access under a defined process

Framework references are educational mappings. They do not imply conformity, certification, a SOC 2 opinion, or any independently validated control design or operating effectiveness.

9. Limitations and recommendations

- Obtain documented supervisor or data-owner decisions. Every original ReviewerDecision remains Pending.
- Maintain a real entitlement catalog with ownership, business justification, location and expiry where appropriate.
- Extend review scope beyond GRP-* memberships to nested privileged groups, file shares, service accounts and connected applications.
- Record approver identity, ticket IDs, exact timestamps, before/after access states and defined due dates for exceptions.
- Consider how active sessions and cached sign-in behavior affect the time at which access revocation becomes effective.

Conclusion

The exercise demonstrated a complete technical access-review loop: inventory, clean baseline comparison, deliberate entitlement exception, successful detection, proof of resource exposure, access removal and effective retesting. Governance certification remains pending and was not represented as complete.